TokTickIT — Lab 3 Submission Report

Users, Roles, IT Staff Ticketing, and Admin Screens

Student: Imanol LABARRERE (ID: 69540460013)

Course: CPE 334 Introduction to Software Engineering

GitHub Repository: ImanolLabarrere/TokTickIT

Peer Reviewers: Léo LEPOUTRE (LeoMin13), Matos07

Branch Integration: `feature/*` → `lab3-staging` → `main`

Total Test Coverage: 145 Server (100%) • 55 Client (100%) • 14 E2E (100%)

Answer Part 1: Git Use with Engineering Workflow

1.1 Staged Integration & Pull Requests Table

Sprint 3 established role-based authorization, IT Staff workflows, and Administrator user management. All planned issues were developed on feature branches, reviewed, and integrated via Pull Requests into `lab3-staging` and `main`:

Issue	Branch Name	PR Link	Reviewer	Scope Delivered	Status
#1	`lab3-staging` (direct)	*Workflow deviation (see 1.4)*	LeoMin13	Sprint 3 engineering specification, authorization matrix, tests.md, ui-spec.md, api-spec.md	Merged
#2	`feature/2-auth-foundation`	PR #25	LeoMin13	User Prisma migration, password hashing (bcryptjs), login/logout, session auth, first password change	Merged
#3	`feature/3-requester-regression`	PR #26	LeoMin13	Session-based Requester scoping, Public Comments, "Problem Appears Resolved" flag, Lab 2 regression tests	Merged
#4	`feature/4-staff-queue`	PR #27	LeoMin13	IT Staff Ticket Queue API & UI, multi-criteria filters, search, sort, pagination, status chips	Merged
#5	`feature/5-staff-ticket-detail`	PR #28	LeoMin13	Staff Ticket Detail: claim, reassign, IT Priority, status transitions, Public Comments vs Internal Notes	Merged
#6	`feature/6-admin-users`	PR #24 / `lab3-staging`	LeoMin13	User Management: list, search, filter, create user, duplicate email validation, self-deactivation guard	Merged
#7	`feature/7-integration-qa`	PR #29	LeoMin13	End-to-end Playwright suites (auth, staff flow, admin), 18 responsive screenshots, final docs	Merged

1.2 Final GitHub Project Kanban Board (All Issues in Done)

BACKLOG (0)	READY (0)	IN PROGRESS (0)	DONE (7) ✓
All items completed	Empty	Empty	**#1** Sprint 3 Engineering Contract
			#2 Auth Foundation & User Model
			#3 Requester Regression & Comments
			#4 IT Staff Ticket Queue
			#5 Staff Ticket Detail & Notes
			#6 Administrator User Management
			#7 Integration QA & Playwright E2E

1.3 Git Commit History Graph

```
*   68aa2ad Merge pull request #29 from ImanolLabarrere/feature/7-integration-qa
|
| * 63bf592 test: E2E flows, authorization matrix, responsive screenshots, final docs (Issue 7)
| *   61a2248 chore: bring lab3-staging up to date with main (Issues 3, 5, 6)
| |
| |/
|/|
* |   891b6f3 Merge pull request #28 from ImanolLabarrere/feature/5-staff-ticket-detail
|
| * | 1e7612d feat: IT Staff ticket detail, claim/reassign, IT Priority, status transitions, internal notes (Issue 5)
* | |   fd9a099 Merge pull request #26 from ImanolLabarrere/feature/3-requester-regression
|
| * | | 9f7ad8b test: fix client tests for session auth, comments and resolved flow (Issue 3)
* | | |   997075a Merge pull request #24 from ImanolLabarrere/lab3-staging
|
*       c22df2f Merge pull request #23 from ImanolLabarrere/lab3-staging
|
| | | | | *   51d5a5c Merge pull request #27 from ImanolLabarrere/feature/4-staff-queue
| | | | | |
| | | | | |/
| | | | |/|
| | | | * | a1f71c3 feat: IT Staff ticket queue, role-aware navigation, staff migration and seed (Issue 4)
| | | |/ /
| | | * / 44f65fe feat: session-based ticket ownership, Public Comments, Problem Appears Resolved (Issue 3)
| | | |/
| | * 7de3687 Merge pull request #25 from ImanolLabarrere/feature/2-auth-foundation
```

1.4 Peer Review Record & Workflow Deviations

Peer reviews were conducted with Léo LEPOUTRE (`LeoMin13`). Two minor process deviations occurred and were transparently recorded in `docs/lab-03/reviewer.md` and `ai-use.md` :

1. **Issue 1 (Specification):** Committed directly to `lab3-staging` without an intermediate PR.
2. **Issues 3, 5, and 6:** Merged directly into `main` due to GitHub default target proposal. This was cleanly resolved before Issue 7 by merging `main` back into `lab3-staging` (commit `61a2248`) to maintain strict linear history.

Clean Repository Structure: Standardized multi-tier layout separating `docs/lab-03/` , `server/tests/lab-03/` , `client/tests/lab-03/` , `e2e/lab-03/` , and `artifacts/lab-03/screenshots/` . `.gitignore` prevents test artifacts, SQLite

binaries, node_modules, and session secrets from entering version control.

Answer Part 2: Spec DD (Specification-Driven Development)

Specification link: `docs/lab-03/specification.md`. Written upfront as Issue 1 before implementation began.

2.1 Sprint Goal & Stakeholder Interpretation

Sprint Goal: Replace the development requester selector with secure email/password authentication, implement session-based identity across all routes, introduce operational IT Staff ticketing workflows (queue, claim/reassign, priority, status transitions, public comments, internal notes), and add a minimalist Administrator screen for user account management.

Stakeholder Interpretation: Move from an unauthenticated prototype to a secure multi-role system where Requesters, IT Staff, and Administrators operate with distinct, server-enforced boundaries. Server-side validation must be authoritative; hiding UI buttons does not constitute authorization.

2.2 Functional Requirements (FR-01 to FR-12)

- **FR-01: Authentication** — Authenticate with email and password, establishing an HTTP-only session cookie.
- **FR-02: Mandatory Password Change** — Users with `mustChangePassword = true` cannot reach normal screens until a valid password is saved.
- **FR-03: Current User & Logout** — `GET /api/auth/me` returns session info; `POST /api/auth/logout` invalidates session.
- **FR-04: Session-Based Requester Scoping** — All ticket/attachment endpoints authorize using `req.session.userId`.
- **FR-05: Requester Comments & Advisory Flag** — Requesters can post Public Comments and mark "Problem Appears Resolved".
- **FR-06: IT Staff Ticket Queue** — Paginated, searchable, filterable, and sortable queue covering all system tickets.
- **FR-07: Claim & Reassign** — IT Staff can claim unassigned tickets or reassign ownership to another active IT Staff member.
- **FR-08: IT Priority & Status Transitions** — IT Staff can adjust IT Priority and execute permitted status transitions.
- **FR-09: Public Comments vs Internal Notes** — Public Comments shared with requester; Internal Notes restricted to IT Staff/Admin.
- **FR-10: Administrator User Management** — List, search, role-filter, create user, edit details, and reset initial password.
- **FR-11: Administrator Safety Guards** — Prevent self-deactivation and prevent removal of the last active Administrator.
- **FR-12: Role-Aware App Shell** — Header dynamically displays authenticated user, role badge, and role-permitted navigation links.

2.3 Server-Side Authorization Matrix

Endpoint	Method	Anonymous	Requester	IT Staff	Administrator
`/api/auth/login`	POST	200 OK	200 OK	200 OK	200 OK
`/api/auth/me`	GET	401 Unauthorized	200 OK	200 OK	200 OK
`/api/tickets`	GET	401 Unauthorized	200 (Scoped)	403 Forbidden	403 Forbidden
`/api/staff/queue`	GET	401 Unauthorized	403 Forbidden	200 OK	403 Forbidden
`/api/staff/tickets/:id/claim`	POST	401 Unauthorized	403 Forbidden	200 OK	200 OK
`/api/staff/tickets/:id/notes`	POST	401 Unauthorized	403 Forbidden	200 OK	200 OK
`/api/admin/users`	GET / POST	401 Unauthorized	403 Forbidden	403 Forbidden	200 OK

Answer Part 3: Test DD and Traceability

Test plan specification link: `docs/lab-03/tests.md`. All 18 Acceptance Criteria map directly to automated suites passing at 100%.

3.1 Acceptance Criteria Traceability Matrix

Test ID	Type	AC / FR	Verification Scope	Test File Path	Result
API-01	API	AC-01, AC-02	Valid login sets cookie; invalid credentials return generic 401	`server/tests/lab-03/auth.api.test.ts`	Pass
API-02	API	AC-03	Inactive account blocked with identical generic 401	`server/tests/lab-03/auth.api.test.ts`	Pass
API-03	API	AC-04, AC-05	`mustChangePassword` blocks protected routes; clears on valid change	`server/tests/lab-03/auth.api.test.ts`	Pass
API-04	API	AC-16	Logout invalidates session; subsequent calls return 401	`server/tests/lab-03/auth.api.test.ts`	Pass
API-05	API	AC-06, AC-07	Client `requesterId` ignored; cross-Requester ticket access returns 404	`server/tests/lab-03/authorization.api.test.ts`	Pass
API-06	API	AC-08, AC-15	Authorization matrix enforced across 10 endpoints & 4 roles	`server/tests/lab-03/authorization.api.test.ts`	Pass
API-07	API	FR-06, AC-17	Staff queue search/filter/sort/pagination; non-staff forbidden	`server/tests/lab-03/staff-queue.api.test.ts`	Pass
API-08	API	AC-09	Claim sets owner + NEW → OPEN; already claimed returns 409	`server/tests/lab-03/staff-ticket-detail.api.test.ts`	Pass
API-09	API	AC-10	Only matrix-listed transitions succeed; invalid transitions return 400	`server/tests/lab-03/staff-ticket-detail.api.test.ts`	Pass
API-10	API	BR-11	IT Priority copies Requested Priority initially; editable only by staff	`server/tests/lab-03/staff-ticket-detail.api.test.ts`	Pass
API-11	API	AC-11	`requesterConfirmedResolved` flag resets on any status change	`server/tests/lab-03/staff-ticket-detail.api.test.ts`	Pass
API-12	API	BR-15, BR-16	Public Comments visible to requester; Internal Notes restricted to staff	`server/tests/lab-03/staff-ticket-detail.api.test.ts`	Pass
API-13	API	AC-12	Duplicate email (case-insensitive) rejected on create and edit	`server/tests/lab-03/admin-users.api.test.ts`	Pass
API-14	API	AC-13	Self-deactivation blocked; deactivated account locked out immediately	`server/tests/lab-03/admin-users.api.test.ts`	Pass
API-15	API	FR-10	User list search/filter/paging; password reset invalidates open session	`server/tests/lab-03/admin-users.api.test.ts`	Pass
API-16	Unit	AC-14	Unit test guarding "never remove the last active Administrator"	`server/tests/lab-03/admin-safety.unit.test.ts`	Pass
UI-01..06	UI	AC-01..17	React component tests: Login, ChangePassword, StaffQueue, StaffDetail, Users, Nav	`client/tests/lab-03/**`	Pass (33 tests)
MIG-01..02	Regr.	AC-18, DoD	All Lab 2 Ticket and Attachment tests pass against authenticated sessions	`server/tests/lab-02/**`, `client/tests/lab-02/**`	Pass (29 tests)

Test ID	Type	AC / FR	Verification Scope	Test File Path	Result
E2E-01..04	E2E	DoD	Playwright suites for Auth, Staff Ticket Lifecycle, Admin Users, and Lab 2 Flows	`e2e/lab-03/*.spec.ts`, `e2e/lab-02/*.spec.ts`	Pass (14 tests)

3.2 Test Results Summary

```
Server Suites:  13 passed (13) — 145 passed (100%) • Duration: 24.3s
Client Suites:  11 passed (11) — 55 passed (100%) • Duration: 18.2s
Playwright E2E: 14 passed (14) — 9 Lab 3 + 5 Lab 2 regression (100%) • Duration: 36.8s
```

Answer Part 4: AI Use with Reflection

AI Documentation link: `docs/lab-03/ai-use.md` .
AI Assistant Used: Claude (Anthropic) & Claude 3.5 Sonnet.

4.1 Selected Key Prompts (Prompt Progression)

1. **Specification Definition (Issue 1):**
   Prompt: "Read the Lab 3 sheet and prepare the specification, API spec, UI spec, and test plan. Do not write implementation code."
2. **Authentication Foundation (Issue 2):**
   Prompt: "Do Issue 2 and tell me what to ADD, not the whole zip. Use bcryptjs for cross-platform compatibility."
3. **Migration Error Recovery:**
   Prompt: "Prisma migration failure: P3006 / P1014 duplicate table Requester. How to safely consolidate migrations without data loss?"
4. **Token-Efficient File Delivery:**
   Prompt: "Give me only the files that changed to avoid token truncation and copy-paste errors."
5. **Requester Regression & Public Comments (Issue 3):**
   Prompt: "Switch the Lab 2 endpoints to the authenticated session and add Public Comments and Problem Appears Resolved action."
6. **IT Staff Ticket Queue (Issue 4):**
   Prompt: "Implement the IT Staff Ticket Queue with multi-parameter filtering (status, priority, owner), search, and pagination."
7. **Staff Ticket Detail & Administrator Management (Issues 5 & 6):**
   Prompt: "Build Staff Ticket Detail (claim, reassign, priority, internal notes) and User Management (CRUD, self-deactivation guard, last admin guard)."
8. **Integration QA & Playwright Suites (Issue 7):**
   Prompt: "Do the QA and E2E Issue. Migrate Lab 2 Playwright specs to real login and capture responsive screenshots at 3 viewports."

4.2 My Reflection

Specification Agent: Generating the comprehensive specification first (authorization matrix, transition matrix, numbered BR rules, and acceptance criteria) made implementation structured and verifiable. Every test could be traced directly to an Acceptance Criterion. The only flaw was process discipline: Issue 1 was committed directly to staging without an initial PR.

Coding Agent: The coding agent was fast and made sound architectural choices (server-side authorization, HTTP-only session cookies, no client-supplied IDs). However, it struggled where it could not execute commands directly: migrations, local database nuances, and test executions. Running test suites locally after every single issue was crucial to catching minor test mock discrepancies and ensuring 100% real-world stability.

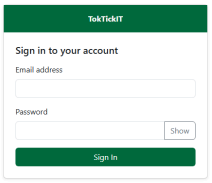
Answer Part 5: Working Login and Password Change UI

5.1 Authentication Features & Security Policy

- **Dual-Field Login:** Email and password fields with busy loading state and inline error banner.
- **Safe Failure Feedback:** Generic "Invalid email or password" returned for unknown emails, bad passwords, and inactive accounts (BR-01, BR-02), preventing account enumeration attacks.
- **Mandatory First Password Change:** Users with `mustChangePassword: true` are intercepted immediately and redirected to the password change screen before any application data is exposed.
- **Password Policy Enforcement:** Minimum 8 characters, at least one letter and one number, and confirmation matching.
- **Session Invalidation:** Logout completely clears the session cookie and prevents subsequent back-button navigation.

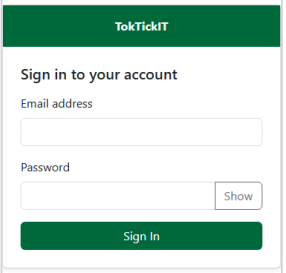
5.2 Responsive Screenshots — Login & Password Change

Login Screen:



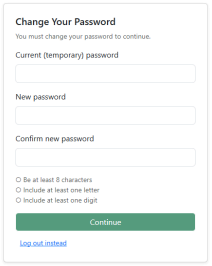
Desktop View (1280px) — Centered Zen Green Login Card

Tablet View (768px) — Form Card & Validation Placement

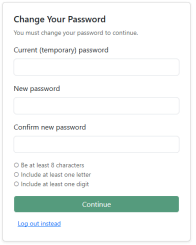


Mobile View (375px) — Full-Width Responsive Inputs

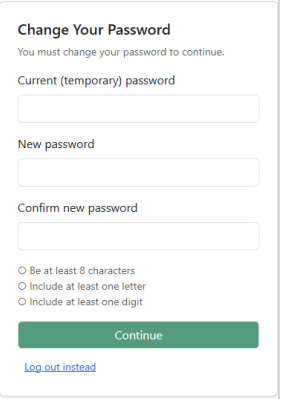
Change Password Screen (Mandatory First Login):



Desktop View (1280px) — Policy Checklist & Mismatch Check



Tablet View (768px) — Accessible Controls



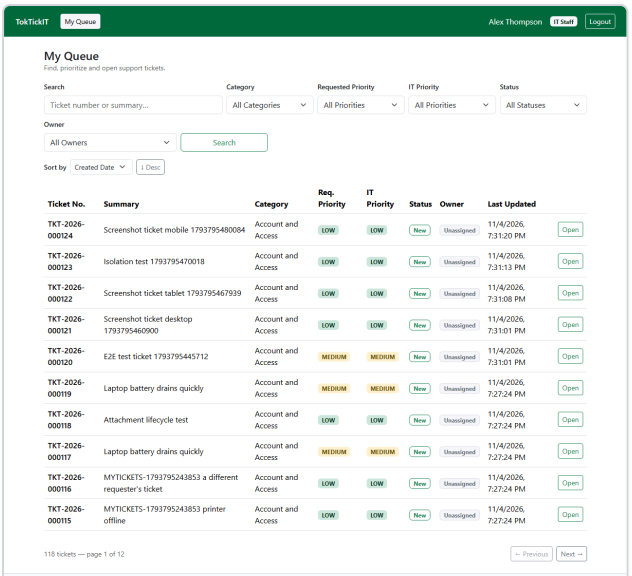
Mobile View (375px) — Clear Policy Feedback

Answer Part 6: Working IT Staff Ticket Queue UI

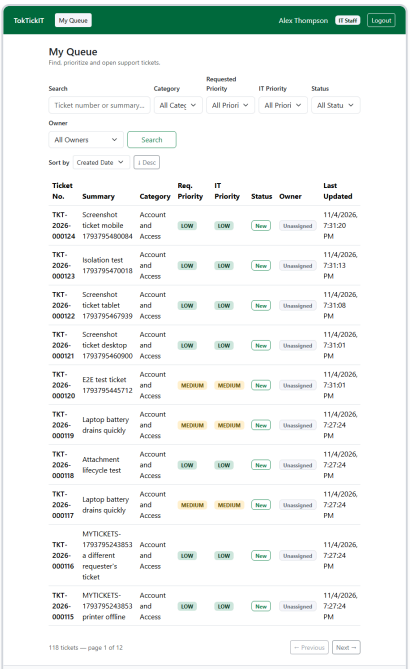
6.1 Operational Queue Capabilities

- **Search & Multi-Parameter Filters:** Text search across ticket number and summary; dropdown filters for Status, IT Priority, and Ticket Owner.
- **Sorting & Pagination:** Sortable table columns with clean server-side pagination metadata (showing range, total count, prev/next controls).
- **Status & Priority Badges:** Visual pills using Zen Green color coding paired with text labels for accessibility.
- **Clear Ownership Indication:** Assigned staff member name displayed or distinct "Unassigned" chip.
- **Empty & No-Results State:** Clean empty state illustration with a "Clear Filters" button when queries match zero tickets.

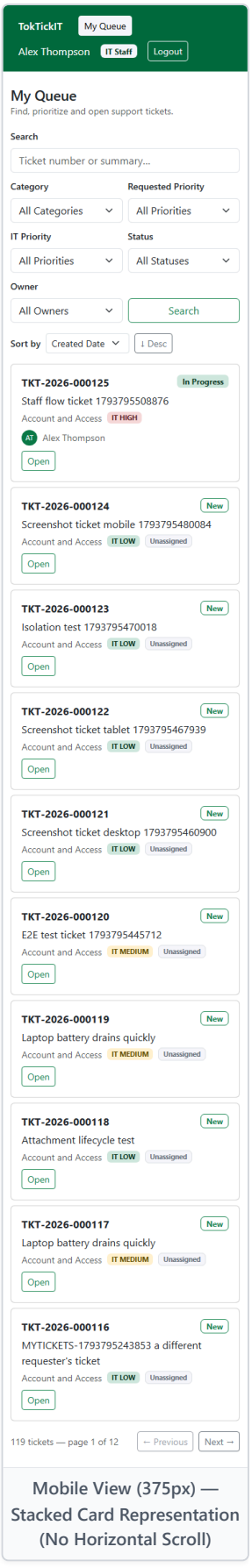
6.2 Responsive Screenshots — IT Staff Ticket Queue



Desktop View (1280px) — Full Queue Table with Filters and Pagination



Tablet View (768px) — Compact Table Layout



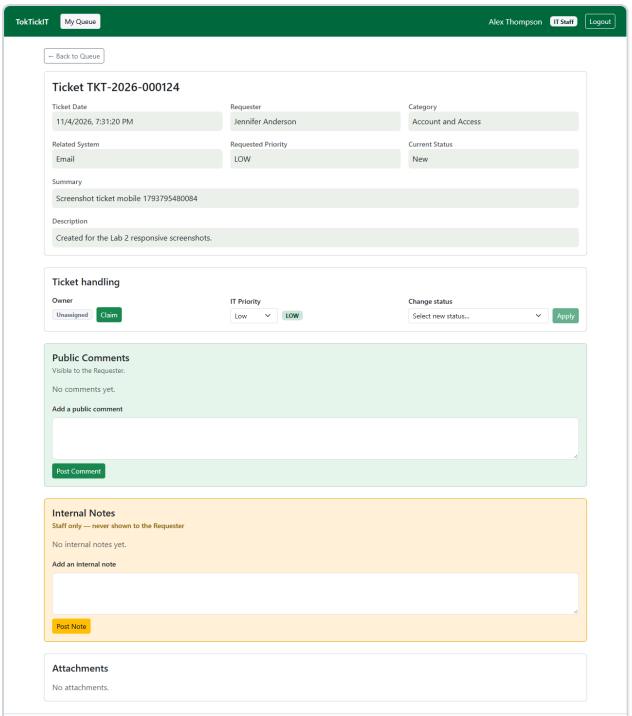
Mobile View (375px) — Stacked Card Representation (No Horizontal Scroll)

Answer Part 7: Working IT Staff Ticket Detail UI

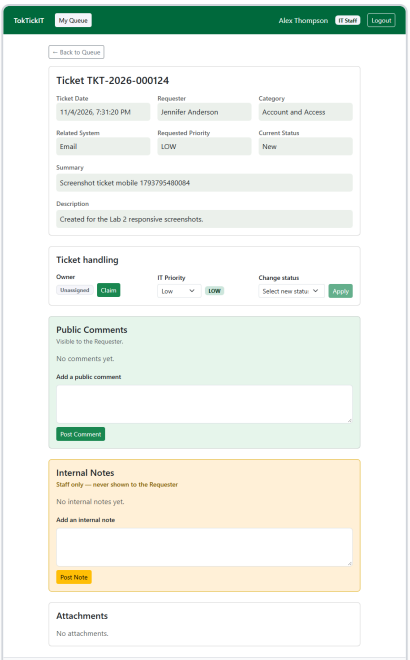
7.1 Operational Actions & Communication Channels

- **Atomic Claim:** Unassigned tickets feature a prominent "Claim Ticket" button that assigns the ticket to the current staff user and updates status from `NEW` to `OPEN`.
- **Reassignment:** Staff can reassign ticket ownership to any active IT Staff member via dropdown.
- **Independent IT Priority:** Staff can adjust IT Priority without overwriting the Requester's original Requested Priority.
- **Status Transition Controls:** Status dropdown presents only valid transitions per the matrix; invalid requests are blocked with HTTP 400.
- **Public Comments vs. Internal Notes:**
  - **Public Comments:** Shared conversation visible to both Requester and IT Staff (rendered in green card containers).
  - **Internal Notes:** Private operational notes visible exclusively to IT Staff and Administrators (rendered in distinct amber containers). Requesters attempting to query notes receive 403 Forbidden.
- **Problem Appears Resolved Flag:** When a requester marks the advisory flag, a banner alerts staff. Resolving the ticket automatically resets the flag.

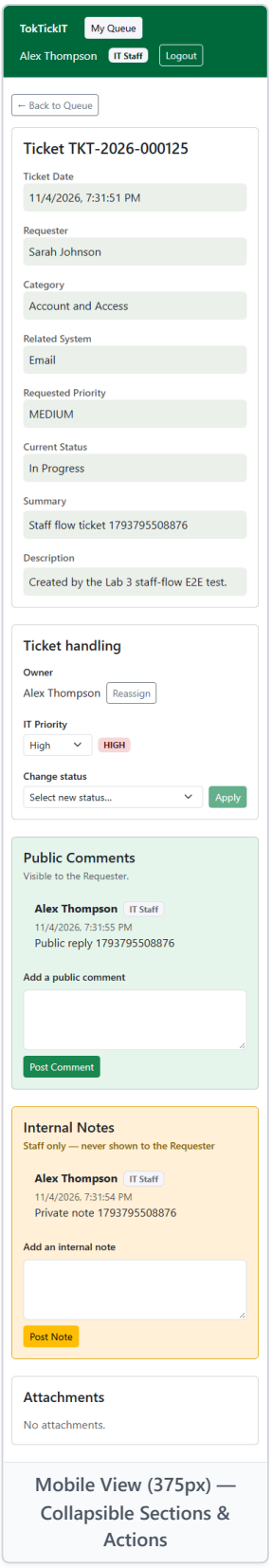
7.2 Responsive Screenshots — Staff Ticket Detail



Desktop View (1280px) — Grouped Header, Notes & Comments Tabs



Tablet View (768px) — Responsive Tabs & Form Fields



Mobile View (375px) — Collapsible Sections & Actions

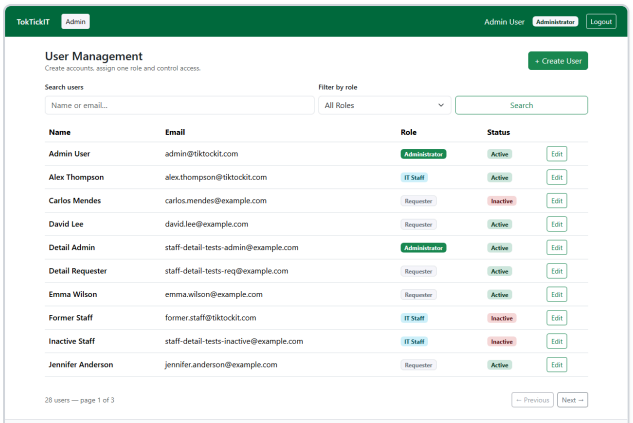
Answer Part 8: Working Administrator User Management UI

8.1 User Management Screen & Safety Guards

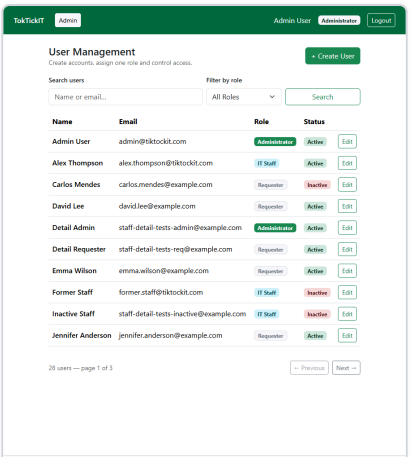
- **User Directory:** Clean table listing all users with Name, Email, Role badge, Status (Active/Inactive), and Edit action.
- **Search & Role Filter:** Live search by user name or email address, with quick role filtering.
- **Create User Modal:** Form with name, email, role selection, active toggle, and generated compliant initial password.
- **Duplicate Email Prevention:** Case-insensitive duplicate check rejects duplicates with clear field-level validation errors (HTTP 400).
- **Safety Rules (BR-18, BR-19):**
  - An Administrator cannot deactivate their own active account.
  - The system blocks deactivating or changing the role of the last active Administrator (protected in unit test `admin-safety.unit.test.ts`).
  - Soft deactivation is used instead of user deletion to preserve ticket history and audit integrity.
- **Password Reset:** Administrators can generate a new temporary password for any user; the user's existing session is immediately invalidated, forcing a password change on next login.

8.2 Responsive Screenshots — User Management & Create Modal

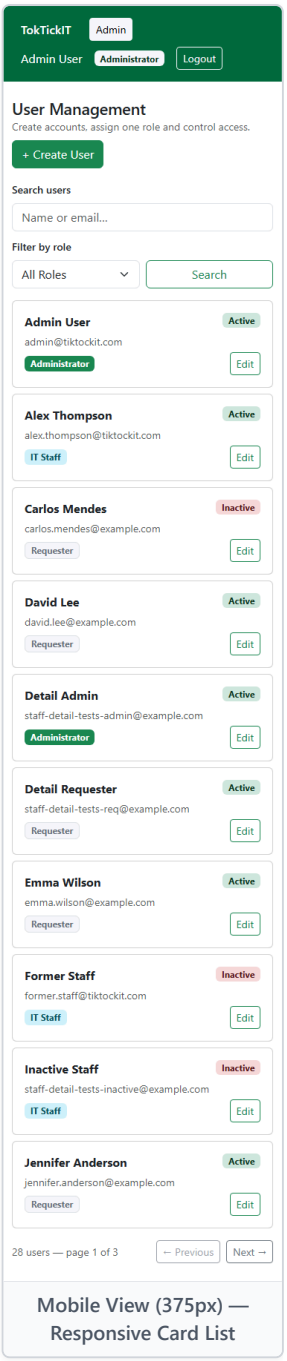
User List:



Desktop View (1280px) — User List with Role & Status Badges

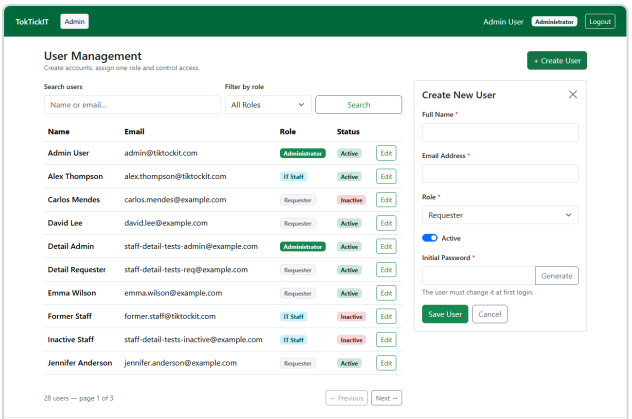


Tablet View (768px) — Compact Grid & Actions

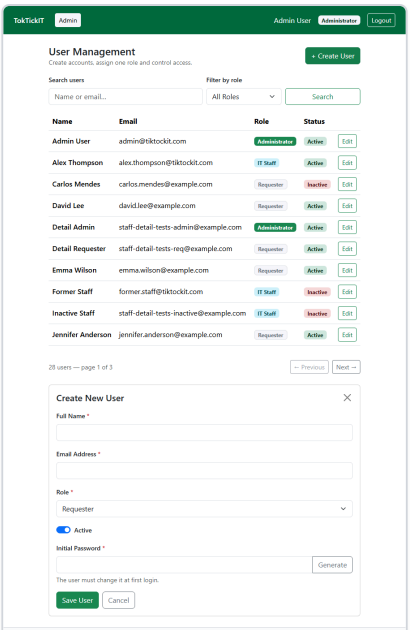


Mobile View (375px) — Responsive Card List

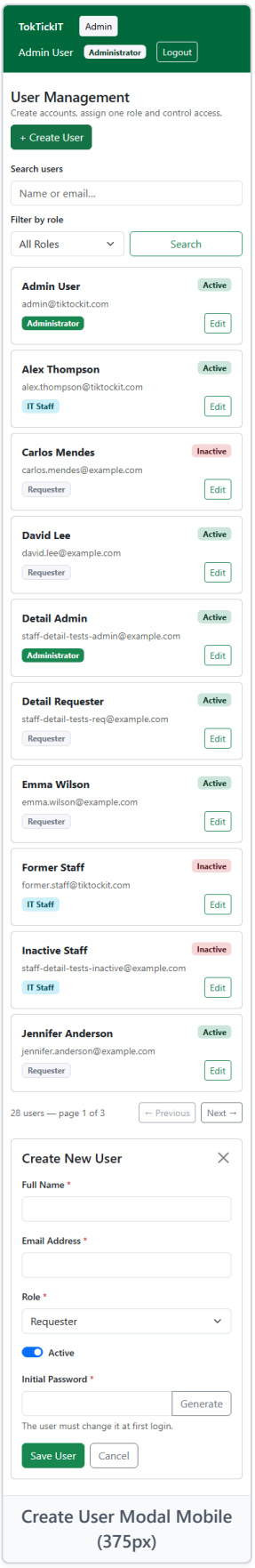
Create User Modal:



Create User Modal Desktop (1280px)



Create User Modal Tablet (768px)



Create User Modal Mobile (375px)

Answer Part 9: Zen Green UI and Responsive Evidence

9.1 Zen Green UI Tokens & Conventions

Lab 3 preserves and extends the Zen Green design system established in Lab 2:

- **Palette:** Primary Forest Green (`#006B3C`), Accent Deep Emerald (`#2d6a4f`), Background Soft Mint (`#EEF2EF`), Card White (`#ffffff`), Border Mint (`#d8f3dc`).
- **Semantic Distinctions:** Public Comments in soft green containers (`#e8f5e9`); Internal Notes in distinct soft amber containers (`#fef3c7`) with amber border (`#f59e0b`).
- **Role-Aware Header:** App shell shows the user's name and role pill with distinct styling (Requester: blue-green, IT Staff: emerald, Administrator: purple-slate).

9.2 Completed Visual and Accessibility Checklist

Check Item	Desktop (1280px)	Tablet (768px)	Mobile (375px)	Status & Verification Evidence
No Clipped Labels or Buttons	Pass	Pass	Pass	Buttons and labels wrap or flex cleanly without clipping
No Overlapping Messages	Pass	Pass	Pass	Banners, modals, and toasts occupy dedicated non-overlapping flows
No Unintended Horizontal Scroll	Pass	Pass	Pass	Mobile viewport (375px) has zero horizontal overflow across all screens
Role Badge & Role Navigation	Pass	Pass	Pass	Role badge clearly legible; navigation hides unauthorized links
Status & Priority Badges	Pass	Pass	Pass	Consistent pill geometry, high-contrast text, non-color text labels
Editable vs Read-Only Fields	Pass	Pass	Pass	Read-only fields clearly distinguished with subtle background and disabled cursors
Public Comments vs Internal Notes	Pass	Pass	Pass	Distinct green vs amber card backgrounds prevents accidental public exposure
Validation Placement	Pass	Pass	Pass	Error messages render adjacent to the offending input fields
Visible Focus Rings	Pass	Pass	Pass	Focus rings visible on keyboard tab navigation (`:focus-visible`)
Mobile Table Adaptability	n/a	n/a	Pass	Queue and User lists collapse to card view on mobile viewports